

Can I trust AI with my data, its answers and my people?

This chapter helps an owner decide what may go into AI tools, what those tools may do alone, and how to bring hidden AI used by staff into the open.

Team 5: [Cohort] · v0.2 · SME: persona/archetype — a fictional 30-person Dutch CNC shop, not a real firm (replace if your proposal names one) · last appraised: 24 Sept 2026

The question, for this kind of SME

A family-owned CNC shop with 30 staff makes custom parts for machine builders. Its most valuable data: customer drawings (often under NDA), price calculations and staff records. The owner asks: **what leaves the building** when we use AI, **when may AI act** for us, and **what if staff use AI without saying so?**

The translation

1. My data — what leaves the building

- Anything typed into a cloud AI tool goes to the provider's servers. **Free versions are the main risk:** the Dutch data protection authority (AP) warns that data entered there may be stored and used for training, and it received more chatbot-related breach reports in 2025 than in 2024 (Accountant.nl, 2025).
- Business plans come with a contract:** by default, they don't train on your data (OpenAI; Microsoft; Anthropic; Mistral AI). Copilot keeps EU prompts in the EU (Microsoft). Always sign the data processing agreement.
- Running AI in-house is possible:** LM Studio or Ollama run an open model on one PC with 16 GB memory and a graphics card (SitePoint, 2026). Nothing leaves the building, but the models are weaker and need upkeep.

2. Its answers — act or only advise

- Use a ladder and start every new use at the bottom: **advise** (a person decides) → **draft for approval** (a named person checks and sends) → **act within fixed limits** (only low-risk, reversible tasks).
- Avoid "excessive agency": give AI only the tools and rights the task needs and let a person approve high-impact actions (OWASP Gen AI Security Project, 2025). Never leave decisions that seriously affect a person to AI alone (European Union, 2016).

3. My people — hidden AI use

- It already happens: 78% of AI users bring their own tools to work (Microsoft & LinkedIn, 2024). Bans alone fail, because employers can't watch everyone (Accountant.nl, 2025).
- Offer one approved tool, a clear rule on what may go in, and block free chatbots (Accountant.nl, 2025). Staff AI training is a legal duty since 2 Feb 2025 (European Union, 2024).

Illustrative use case (CRISP-DM): drafting quotes from customer requests

Phase	At the persona firm
Business understanding	The estimator loses mornings reading requests for quotes (RFQs). Goal: less reading; prices stay with the estimator.
Data understanding	Honest reality: past quotes are spread over Excel and the ERP system, with inconsistent material names; some drawings are scans; many fall under NDA.
Data preparation	Select 50 past RFQs. Remove unneeded personal data. Fix one field list: material, dimensions, tolerances, quantity, delivery date.
Modelling	No custom model. A business-tier AI assistant fills in the field list; the existing costing sheet still sets the price.
Evaluation	Compare the AI's fields with what the estimator entered on the 50 RFQs. Count errors per field (watch tolerances). Set a pass level first.
Deployment	Draft for approval only. The estimator checks every draft; recheck 10 random drafts a month.

Recommended tooling (no-code first)

Option	What it gives you	Effort
Chat assistant, business plan (ChatGPT Business, Claude Team, Mistral)	Safe replacement for free chatbots (OpenAI; Anthropic; Mistral AI)	Low: sign up, sign the agreement, write a usage rule
Microsoft 365 Copilot	AI inside Outlook, Word and Excel; EU data boundary (Microsoft)	Low–medium: licence per user; check file access first
Power Automate / Zapier + AI step	RFQ emails flow into a draft-quote sheet	Medium: a few days' setup, with an approval step
Local model (LM Studio / Ollama)	Nothing leaves the building	Medium–high: capable PC plus upkeep (SitePoint, 2026)

Responsible AI & trust

- Data ownership:** only business plans with a signed agreement, or a local model. Never free chatbots (Accountant.nl, 2025).
- Reliability:** only as far as the 50-RFQ test shows; AI can confidently misread a tolerance. Every output is a draft.

- **GDPR:** keep personal data out of prompts, list each AI tool in the processing register, report leaks to the AP within 72 hours (European Union, 2016).
- **Guardrails and human in the loop:** one approved tool, a written input rule, and a named person approving every quote (OWASP Gen AI Security Project, 2025).
- **For staff:** AI takes over the reading, not the judgement. Train people and let them say which AI they use without blame (European Union, 2024; Microsoft & LinkedIn, 2024).

First five steps for an owner

1. **Ask the team** which AI tools they use now — with no blame.
2. **Choose one business-tier tool** and sign its data processing agreement.
3. **Write a one-page AI rule:** which tool, what may and may not go in, who approves.
4. **Run a one-hour AI literacy session** and keep a record of it (European Union, 2024).
5. **Test the quote use case** on 50 past RFQs before going live.

References

- Accountant.nl. (2025). *AP slaat alarm over datalekken door AI* [The AP raises the alarm over data leaks caused by AI; translated from Dutch]. Retrieved from Accountant.nl: <https://www.accountant.nl/nieuws/2025/12/ap-slaat-alarm-over-datalekken-door-ai/>
- Anthropic. (n.d.). *Is my data used for model training?* Retrieved from Anthropic Privacy Center: <https://privacy.claude.com/en/articles/7996868-is-my-data-used-for-model-training>
- CBS (Statistics Netherlands). (2025). *Use of artificial intelligence (AI) by businesses is increasing* [translated from Dutch]. Retrieved from CBS: <https://www.cbs.nl/nl-nl/nieuws/2025/09/gebruik-kunstmatige-intelligentie--ai---door-bedrijven-neemt-toe>
- European Union. (2016). *General Data Protection Regulation (EU) 2016/679, Articles 22, 30, 33 and 35*. Retrieved from EUR-Lex: <https://eur-lex.europa.eu/eli/reg/2016/679/oj>
- European Union. (2024). *Artificial Intelligence Act, Article 4: AI literacy (Regulation (EU) 2024/1689)*. Retrieved from EU Artificial Intelligence Act: <https://artificialintelligenceact.eu/article/4/>
- Microsoft & LinkedIn. (2024). *2024 Work Trend Index: AI at work is here. Now comes the hard part*. Retrieved from Microsoft WorkLab: <https://www.microsoft.com/en-us/worklab/work-trend-index/ai-at-work-is-here-now-comes-the-hard-part>
- Microsoft. (n.d.). *Enterprise data protection in Microsoft 365 Copilot and Copilot Chat*. Retrieved from Microsoft Learn: <https://learn.microsoft.com/en-us/microsoft-365/copilot/enterprise-data-protection>
- Mistral AI. (n.d.). *Privacy and data controls*. Retrieved from Mistral Docs: <https://docs.mistral.ai/admin/monitor-comply/privacy-data-controls>
- OpenAI. (n.d.). *Business data privacy, security, and compliance*. Retrieved from OpenAI: <https://openai.com/business-data/>
- OWASP Gen AI Security Project. (2025). *LLM06:2025 Excessive Agency*. Retrieved from OWASP Gen AI Security Project: <https://genai.owasp.org/llmrisk/llm06-sensitive-information-disclosure/>
- SitePoint. (2026). *Ollama setup guide 2026: local LLM guide*. Retrieved from SitePoint: <https://www.sitepoint.com/ollama-setup-guide-2026/>